

2 HIGH 3 MED 4 LOW

S

Spoofing

HIGH

T

Tampering

MED

R

Repudiation

LOW

I

Info Discl.

HIGH

D

DoS

MED

E

Elev. Priv.

MED

TOP 3 ATTACK VECTORS

01

EC2 Metadata SSRF -> credential theft

Une SSRF applicative sur EC2 t2.micro permet d'appeler http://169.254.169.254/ et d'exfiltrer les credentials IAM temporaires du role attache. Sans IMDSv2 enforce via Terraform, le vecteur est trivial a exploiter depuis le web.

STRIDE: I + E OWASP: SSRF Prod + Staging

Fix: IMDSv2: http_tokens=required + hop_limit=1 dans Terraform

CRITICAL

02

Over-permissive IAM -> SSM secrets dump

Si le role IAM de l'EC2 a ssm:GetParameter/* au lieu d'un ARN precis, un attaquant qui compromet l'instance peut dumper tous les secrets des 3 environnements via l'API SSM. Pas de rotation automatique native dans Parameter Store.

STRIDE: I + E Misconfiguration Cross-env

Fix: IAM: ssm:GetParameter sur ARN exact + condition aws:ResourceTag/env

HIGH

03

CloudFront WAF bypass via direct EC2 IP

Sans ALB, l'EC2 Nginx est accessible directement par IP publique si le Security Group autorise 0.0.0.0/0:443. Un attaquant qui decouvre l'IP (DNS history, Shodan) contourne totalement CloudFront et le Shield Basic.

STRIDE: D + S Misconfiguration WAF bypass

Fix: SG: ingress 443 uniquement depuis aws_ec2_managed_prefix_list CloudFront

HIGH

MITIGATIONS TERRAFORM

CRITICAL

SSRF / IMDSv2

- http_tokens = required

- http_put_response_hop_limit = 1

- WAF: bloquer 169.254.169.254

HIGH

IAM over-permissive

- ssm:GetParameter sur ARN exact

- Condition: ResourceTag/env == env

- CloudTrail alarm cross-env

HIGH

IP directe bypass

- SG: allow 443 from CF prefix list

- data.aws_ec2_managed_prefix_list

- .cloudfront.id

RISK MATRIX

	Low likelihood	Med likelihood	High likelihood
Critical impact	-	SSRF	-
High impact	CF bypass	IAM dump	-
Med impact	-	DoS	-
Residuel apres mitigations:			
	IAM -> MED	SSRF -> MED	CF bypass -> LOW